

05A / CYBER SECURITY: PLAN AND RISKS

What we secure — and what can go wrong

Zelle is right to treat cyber security as a management issue, not a technical afterthought. The first security decision is what this site is not: it is a public marketing website, not a client portal, matter system, or place for privileged files. That limit is intentional. It shrinks the blast radius if something goes wrong.

The plan is layered: named people with two-factor authentication, secrets kept out of source code, HTTPS and platform DDoS protection on Vercel, preview-then-publish releases with rollback, continuous monitoring under the \$350 monthly plan, and form copy that tells visitors not to send confidential matter information. Section 05 lists the controls. This page is the risk conversation behind them.

What can go wrong — and the plan

What can go wrong	Why it matters to a law firm	How we plan for it
Stolen admin credentials	Someone changes bios, posts false content, or publishes in the firm's name.	Named accounts only. Two-factor authentication for administrators. Least-privilege roles. Access removed when people leave.
Site defacement or a bad publish	A public page is altered or a draft goes live by mistake.	Preview before production. Versioned releases. Fast rollback to the last good deploy. Production launch requires a named Zelle approver.
Contact-form abuse, or a visitor sending privileged facts	Spam floods the inbox, or someone treats the form like a matter intake channel.	The form is not a client portal. On-page warning against confidential or privileged material. Submissions go to a controlled admin inbox, not a public mailbox.
Site taken offline (DDoS or outage)	Clients and recruits cannot reach the firm; it looks like a crisis even when it is not.	Vercel edge delivery, platform DDoS mitigation, HTTPS, uptime monitoring, and 24/7 P1 response (site down or all forms failing) under the monthly plan.
A software dependency is compromised	An update in the stack becomes the way in.	Managed framework and dependency updates. Secrets live in Vercel environment variables, not in GitHub. Production, preview, and development settings are separated.
DNS or domain hijack	Traffic is pointed at a fake site. Email is a separate, higher-stakes risk.	Only website DNS records change at cutover. MX, SPF, DKIM, and DMARC stay with Microsoft 365 unless Zelle separately authorizes a change. Domain registrar access remains Zelle's.
Impersonation / look-alike phishing	A third party copies the look of the site or the firm name. That is mostly off-site.	Clean HTTPS on the real domain, restrained public forms, and no matter data on the site. Registrar and mailbox security remain Zelle's to operate. We will flag obvious issues we see.

What this proposal does not claim

This is not a security warranty, a formal penetration test, incident forensics, or a certification. Those are specialist engagements if management wants them. We also do not operate Zelle's Microsoft 365 tenant, domain registrar, or attorney laptops. The website plan is designed so a public-site incident is embarrassing and recoverable — not a privilege or client-data event.

The practical ask of management

Approve the site remaining a public brochure with a warning on forms. Require two-factor authentication for anyone who can publish. Keep domain and email credentials with a short named list at the firm. Treat a full security audit or penetration test as a separate decision if the partnership wants one before or after launch.